

CONTROL 14

Security Awareness and Skills Training

Safeguards: 9	IG1: 8/9	IG2: 9/9	IG3: 9/9
---------------	----------	----------	----------

Overview

Establish and maintain a security awareness program to influence behavior among the workforce to be security conscious and properly skilled to reduce cybersecurity risks to the enterprise.

Why is this Control critical?

The actions of people play a critical part in the success or failure of an enterprise’s security program. It is easier for an attacker to entice a user to click a link or open an email attachment to install malware in order to get into an enterprise, than to find a network exploit to do it directly.

Users themselves, both intentionally and unintentionally, can cause incidents as a result of mishandling sensitive data, sending an email with sensitive data to the wrong recipient, losing a portable end-user device, using weak passwords, or using the same password they use on public sites.

No security program can effectively address cyber risk without a means to address this fundamental human vulnerability. Users at every level of the enterprise have different risks. For example: executives manage more sensitive data; system administrators have the ability to control access to systems and applications; and users in finance, human resources, and contracts all have access to different types of sensitive data that can make them targets.

The training should be updated regularly. This will increase the culture of security and discourage risky workarounds.

Procedures and tools

An effective security awareness training program should not just be a canned, once-a-year training video coupled with regular phishing testing. While annual training is needed, there should also be more frequent, topical messages and notifications about security. This might include messages about: strong password-use that coincides with a media report of password dump, the rise of phishing during tax time, or increased awareness of malicious package delivery emails during the holidays.

Training should also consider the enterprise's different regulatory and threat posture. Financial firms might have more compliance-related training on data handling and use, healthcare enterprises on handling healthcare data, and merchants for credit card data.

Social engineering training, such as phishing tests, should also include awareness of tactics that target different roles. For example, the financial team will receive BEC attempts posing as executives asking to wire money, or receive emails from compromised partners or vendors asking to change the bank account information for their next payment.

For more comprehensive treatment of this topic, the following resources are helpful to build an effective security awareness program:

NIST® SP 800-50 Infosec Awareness Training:

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-50r1.pdf>

National Cyber Security Centre (UK): <https://www.ncsc.gov.uk/guidance/10-steps-user-education-and-awareness>

EDUCAUSE: <https://www.educause.edu/focus-areas-and-initiatives/policy-and-security/cybersecurity-program/awareness-campaigns>

National Cyber Security Alliance (NCSA): <https://staysafeonline.org/>

SANS: <https://www.sans.org/security-awareness-training/resources>

For guidance on configuring home routers see the CIS Controls Telework and Small Office Network Security Guide:

<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Safeguards

Safeguard 14.1: Establish and Maintain a Security Awareness Program

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain a security awareness program. The purpose of a security awareness program is to educate the enterprise’s workforce on how to interact with enterprise assets and data in a secure manner. Conduct training at hire and, at a minimum, annually. Review and update content annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members to recognize social engineering attacks, such as phishing, business email compromise (BEC), pretexting, and tailgating.

Safeguard 14.3: Train Workforce Members on Authentication Best Practices

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members on authentication best practices. Example topics include MFA, password composition, and credential management.

Safeguard 14.4: Train Workforce on Data Handling Best Practices

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members on how to identify and properly store, transfer, archive, and destroy sensitive data. This also includes training workforce members on clear screen and desk best practices, such as locking their screen when they step away from their enterprise asset, erasing physical and virtual whiteboards at the end of meetings, and storing data and assets securely.

Safeguard 14.5: Train Workforce Members on Causes of Unintentional Data Exposure

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members to be aware of causes for unintentional data exposure. Example topics include mis-delivery of sensitive data, losing a portable end-user device, or publishing data to unintended audiences.

Safeguard 14.6: Train Workforce Members on Recognizing and Reporting Security Incidents

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members to be able to recognize a potential incident and be able to report such an incident.

Safeguard 14.7: Train Workforce on How to Identify and Report if Their Enterprise Assets are Missing Security Updates

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce to understand how to verify and report out-of-date software patches or any failures in automated processes and tools. Part of this training should include notifying IT personnel of any failures in automated processes and tools.

Safeguard 14.8: Train Workforce on the Dangers of Connecting to and Transmitting Enterprise Data Over Insecure Networks

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members on the dangers of connecting to, and transmitting data over, insecure networks for enterprise activities. If the enterprise has remote workers, training must include guidance to ensure that all users securely configure their home network infrastructure.

Safeguard 14.9: Conduct Role-Specific Security Awareness and Skills Training

Asset Type: Users	Security Function: Protect	IG2	IG3
-------------------	----------------------------	-----	-----

Conduct role-specific security awareness and skills training. Example implementations include secure system administration courses for IT professionals, OWASP® Top 10 vulnerability awareness and prevention training for web application developers, and advanced social engineering awareness training for high-profile roles.

CONTROL 15

Service Provider Management

Safeguards: 7	IG1: 1/7	IG2: 4/7	IG3: 7/7
---------------	----------	----------	----------

Overview

Develop a process to evaluate service providers who hold sensitive data, or are responsible for an enterprise’s critical IT platforms or processes, to ensure these providers are protecting those platforms and data appropriately.

Why is this Control critical?

In our modern, connected world, enterprises rely on vendors and partners to help manage their data or rely on infrastructure for core applications or functions.

There have been numerous examples where third-party breaches have significantly impacted an enterprise; for example, as early as the late 2000s, payment cards were compromised after attackers infiltrated smaller service providers in the retail industry. More recent examples include ransomware attacks that impact an enterprise indirectly, due to one of their service providers being locked down, causing disruption to business. Or worse, if directly connected, a ransomware attack could encrypt data on the main enterprise.

Most data security and privacy regulations require their protection extend to service providers, such as with Health Insurance Portability and Accountability Act (HIPAA) Business Associate agreements in healthcare, Federal Financial Institutions Examination Council (FFIEC) requirements for the financial industry, and the United Kingdom (U.K.) Cyber Essentials. Third-party trust is a core Governance Risk and Compliance (GRC) function, as risks that are not managed within the enterprise are transferred to entities outside the enterprise.

While reviewing the security of third-parties has been a task performed for decades, there is not a universal standard for assessing security; and, many service providers are being audited by their customers multiple times a month, causing impacts to their own productivity. This is because every enterprise has a different “checklist” or set of standards to grade the service provider. There are only a few industry standards, such as in finance, with the Shared Assessments program, or in higher education, with their Higher Education Community Vendor Assessment Toolkit (HECVAT). Insurance companies selling cybersecurity policies also have their own measurements.

While an enterprise might put a lot of scrutiny into large cloud or application hosting companies because they are hosting their email or critical business applications, smaller firms are often a greater risk. Often times, a service provider contracts with additional parties to provide other plugins or services, such as when a third-party uses a fourth-party platform or product to support the main enterprise.

Procedures and tools

Most enterprises have traditionally used standard checklists, such as ones from ISO 27001 or the CIS Controls. Often, this process is managed through spreadsheets; however, there are online platforms now that allow central management of this process. The focus of this CIS Control though is not on the checklist; instead it is on the fundamentals of the program. Make sure to revisit annually, as relationships and data may change.

No matter what the enterprise's size, there should be a policy about reviewing service providers, an inventory of these vendors, and a risk rating associated with their potential impact to the business in case of an incident. There should also be language in the contracts to hold them accountable if there is an incident that impacts the enterprise.

There are third-party assessment platforms that have an inventory of thousands of service providers, which attempt to provide a central view of the industry, to help enterprises make more informed risk decisions. These platforms often have a dynamic risk score for service providers, based (usually) on passive technical assessments, or enriched through other firms' third-party assessments.

When performing reviews, focus on the services or departments of the provider that are supporting the enterprise. A service provider that has a managed security service contract, or retainer, and holds cybersecurity insurance, can also help with risk reduction.

It is also important to securely decommission service providers when contracts are completed or terminated. Decommission activities may include user and service account deactivation, termination of data flows, and secure disposal of enterprise data within service provider systems.

NIST® 800-88r1: Guidelines for Media Sanitization, as appropriate: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>

Safeguards

Safeguard 15.1: Establish and Maintain an Inventory of Service Providers

Asset Type: Users	Security Function: Identify	IG1	IG2	IG3
-------------------	-----------------------------	-----	-----	-----

Establish and maintain an inventory of service providers. The inventory is to list all known service providers, include classification(s), and designate an enterprise contact for each service provider. Review and update the inventory annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 15.2: Establish and Maintain a Service Provider Management Policy

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Establish and maintain a service provider management policy. Ensure the policy addresses the classification, inventory, assessment, monitoring, and decommissioning of service providers. Review and update the policy annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 15.3: Classify Service Providers

Asset Type: Users	Security Function: Govern	IG2	IG3
-------------------	---------------------------	-----	-----

Classify service providers. Classification consideration may include one or more characteristics, such as data sensitivity, data volume, availability requirements, applicable regulations, inherent risk, and mitigated risk. Update and review classifications annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 15.4: Ensure Service Provider Contracts Include Security Requirements

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Ensure service provider contracts include security requirements. Example requirements may include minimum security program requirements, security incident and/or data breach notification and response, data encryption requirements, and data disposal commitments. These security requirements must be consistent with the enterprise’s service provider management policy. Review service provider contracts annually to ensure contracts are not missing security requirements.

Safeguard 15.5: Assess Service Providers

Asset Type: Users	Security Function: Govern	IG3
-------------------	---------------------------	-----

Assess service providers consistent with the enterprise's service provider management policy. Assessment scope may vary based on classification(s), and may include review of standardized assessment reports, such as Service Organization Control 2 (SOC 2) and Payment Card Industry (PCI) Attestation of Compliance (AoC), customized questionnaires, or other appropriately rigorous processes. Reassess service providers annually, at a minimum, or with new and renewed contracts.

Safeguard 15.6: Monitor Service Providers

Asset Type: Data	Security Function: Govern	IG3
------------------	---------------------------	-----

Monitor service providers consistent with the enterprise's service provider management policy. Monitoring may include periodic reassessment of service provider compliance, monitoring service provider release notes, and dark web monitoring.

Safeguard 15.7: Securely Decommission Service Providers

Asset Type: Data	Security Function: Protect	IG3
------------------	----------------------------	-----

Securely decommission service providers. Example considerations include user and service account deactivation, termination of data flows, and secure disposal of enterprise data within service provider systems.

CONTROL 16

Application Software Security

Safeguards: 14	IG1: 0/14	IG2: 11/14	IG3: 14/14
----------------	-----------	------------	------------

Overview

Manage the security life cycle of in-house developed, hosted, or acquired software to prevent, detect, and remediate security weaknesses before they can impact the enterprise.

Why is this Control critical?

Applications provide a human-friendly interface to allow users to access and manage data in a way that is aligned to business functions. They also minimize the need for users to deal directly with complex (and potentially error-prone) system functions, like logging into a database to insert or modify files. Enterprises use applications to manage their most sensitive data and control access to system resources. Therefore, an attacker can use the application itself to compromise the data, instead of an elaborate network and system hacking sequence that attempts to bypass network security controls and sensors. This is why protecting user credentials (specifically application credentials) defined in CIS Control 6 is so important.

Lacking credentials, application flaws are the attack vector of choice. However, today’s applications are developed, operated, and maintained in a highly complex, diverse, and dynamic environment. Applications run on multiple platforms: web, mobile, cloud, etc., with application architectures that are more complex than legacy client-server or database-web server structures. Development life cycles have become shorter, transitioning from months or years in long waterfall methodologies, to DevOps cycles with frequent code updates. Also, applications are rarely created from scratch, and are often “assembled” from a complex mix of development frameworks, libraries, existing code, and new code. There are also modern and evolving data protection regulations dealing with user privacy. These may require compliance to regional or sector-specific data protection requirements.

These factors make traditional approaches to security, like control (of processes, code sources, run-time environment, etc.), inspection, and testing, much more challenging. Also, the risk that an application vulnerability introduces might not be understood, except in a specific operational setting or context.